

Northbridge - Control Crosswalk and Testing

Controls	15
Tested Controls	5
Exceptions	3
High Findings	1
Pass Rate	40%
Assessment Date	2026-09-02

High Criticality			
Control Domain	Control Count	Why It Matters	Interview Point
Identity	3	2 Access is central to SOC 2 and customer trust.	MFA evidence must cover the population.
Vulnerability	2	2 Known weaknesses must be governed through SLAs.	A scanner is not a program by itself.
Detection	1	1 Logs need owners and alert routing.	Detection maturity is evidence plus response.
Response / Recovery	4	0 Plans must be exercised and recovery tested.	A plan without testing is weak evidence.
Vendor / Change	2	1 Third parties and change can create hidden risk.	Conditional approval is a risk decision.
Training / Data / Cloud	3	1 Control coverage must match business scope.	Cloud controls need cloud-specific evidence.

Control ID	Control Name	Control Statement	Domain	Owner	Frequency	Evidence	NIST Mapping	CIS	ISO	SOC 2	Control Criticality
AC-01	Multifactor Authentication	All workforce users use MFA; privileged users use phishing-resistant MFA where supported.	Identity	VP of IT	Continuous	MFA policy export; enrollment report; exception log	NIST CSF PR.AA; NIST 800-53 IA-2	CIS 6	ISO 27002 5.16, 5.17	SOC 2 CC6	High
AC-02	Quarterly Access Review	Critical application owners review user access quarterly and document removals or approvals.	Identity	GRC Lead	Quarterly	Access review export; reviewer signoff; remediation evidence	NIST 800-53 AC-2, AC-6	CIS 5, 6	ISO 27002 5.18	SOC 2 CC6	High
AC-03	Terminated User Removal	Departing users are removed from SSO and critical SaaS applications within one business day.	Identity	People Ops	Per termination	HR termination ticket; SSO deactivation log	NIST 800-53 PS-4, AC-2	CIS 5	ISO 27002 5.18	SOC 2 CC6	Medium
VM-01	Vulnerability Scanning	Production systems are scanned at least monthly and findings are tracked.	Vulnerability	Security Engineer	Monthly	Scan report; ticket export	NIST 800-53 RA-5	CIS 7	ISO 27002 8.8	SOC 2 CC7	High
VM-02	Critical Vulnerability Remediation	Critical vulnerabilities are remediated or exception-approved within SLA.	Vulnerability	Security Engineer	Monthly	Aging report; exception approvals	NIST 800-53 SI-2	CIS 7	ISO 27002 8.8	SOC 2 CC7	High
LOG-01	Security Logging	Critical cloud, identity, and SaaS logs are enabled, retained, and monitored.	Detection	Security Operations	Continuous	Log source inventory; alert routing matrix	NIST 800-53 AU-6, SI-4	CIS 8	ISO 27002 8.15	SOC 2 CC7	High
IR-01	Incident Response Plan	Incident-response plan defines roles, escalation, communications, and evidence retention.	Response	CISO	Annual	IR plan; approval record	NIST 800-53 IR-4; NIST SP 800-61	CIS 17	ISO 27002 5.24	SOC 2 CC7	Medium
IR-02	Incident Tabletop Exercise	Northbridge performs an annual tabletop exercise and tracks lessons learned.	Response	CISO	Annual	Exercise agenda; participant list; lessons learned	NIST 800-53 IR-3	CIS 17	ISO 27002 5.24	SOC 2 CC7	Medium
BC-01	Backup Monitoring	Critical backups are monitored and failures are remediated.	Recovery	Infrastructure	Daily	Backup job logs; failure tickets	NIST 800-53 CP-9	CIS 11	ISO 27002 8.13	SOC 2 A1	Medium
BC-02	Backup Restoration Test	Backup restoration is tested at least annually.	Recovery	Infrastructure	Annual	Restore test record; RTO/RPO results	NIST 800-53 CP-10	CIS 11	ISO 27002 8.13	SOC 2 A1	Medium
TPRM-01	Critical Vendor Review	Critical vendors are assessed before onboarding and annually thereafter.	Vendor Risk	GRC Lead	Annual	Vendor assessment; SOC report; findings register	NIST SP 800-161; NIST CSF GV.SC	CIS 15	ISO 27002 5.19	SOC 2 CC9	High
CHG-01	Production Change Approval	Production changes require review, approval, and emergency post-review.	Change	Engineering Manager	Per change	Pull request; approval; emergency review record	NIST 800-53 CM-3	CIS 4	ISO 27002 8.32	SOC 2 CC8	Medium
SEC-01	Security Awareness Training	Employees and contractors complete annual security awareness training.	Training	People Ops	Annual	Training completion report	NIST 800-53 AT-2	CIS 14	ISO 27002 6.3	SOC 2 CC2	Medium
DATA-01	Data Retention and Disposal	Customer data retention and deletion are documented and periodically reviewed.	Data Protection	Legal / Privacy	Annual	Retention matrix; deletion evidence	NIST 800-53 SI-12	CIS 3	ISO 27002 5.33	SOC 2 Confidentiality	Medium
CLD-01	Cloud Configuration Monitoring	Cloud configuration baselines are monitored and exceptions are reviewed.	Cloud Security	Cloud Engineering	Monthly	Configuration alerts; exception review	NIST 800-53 CM-2, AC-3	CIS 4	ISO 27017:2026	SOC 2 CC7	High

Control ID	Control Name	NIST CSF / 800-53	CIS v8.1	ISO 27001/27002	SOC 2 / AICPA TSC	Cloud / Supply Chain Note	Why This Mapping Stands Out
AC-01	Multifactor Authentication	NIST CSF PR.AA; NIST 800-53 IA-2	CIS 6	ISO 27002 5.16, 5.17	SOC 2 CC6	N/A	One internal control can satisfy multiple external obligations when evidence is well designed.
AC-02	Quarterly Access Review	NIST 800-53 AC-2, AC-6	CIS 5, 6	ISO 27002 5.18	SOC 2 CC6	N/A	One internal control can satisfy multiple external obligations when evidence is well designed.
AC-03	Terminated User Removal	NIST 800-53 PS-4, AC-2	CIS 5	ISO 27002 5.18	SOC 2 CC6	N/A	One internal control can satisfy multiple external obligations when evidence is well designed.
VM-01	Vulnerability Scanning	NIST 800-53 RA-5	CIS 7	ISO 27002 8.8	SOC 2 CC7	N/A	One internal control can satisfy multiple external obligations when evidence is well designed.
VM-02	Critical Vulnerability Remediation	NIST 800-53 SI-2	CIS 7	ISO 27002 8.8	SOC 2 CC7	N/A	One internal control can satisfy multiple external obligations when evidence is well designed.
LOG-01	Security Logging	NIST 800-53 AU-6, SI-4	CIS 8	ISO 27002 8.15	SOC 2 CC7	N/A	One internal control can satisfy multiple external obligations when evidence is well designed.
IR-01	Incident Response Plan	NIST 800-53 IR-4; NIST SP 800-61	CIS 17	ISO 27002 5.24	SOC 2 CC7	N/A	One internal control can satisfy multiple external obligations when evidence is well designed.
IR-02	Incident Tabletop Exercise	NIST 800-53 IR-3	CIS 17	ISO 27002 5.24	SOC 2 CC7	N/A	One internal control can satisfy multiple external obligations when evidence is well designed.
BC-01	Backup Monitoring	NIST 800-53 CP-9	CIS 11	ISO 27002 8.13	SOC 2 A1	N/A	One internal control can satisfy multiple external obligations when evidence is well designed.
BC-02	Backup Restoration Test	NIST 800-53 CP-10	CIS 11	ISO 27002 8.13	SOC 2 A1	N/A	One internal control can satisfy multiple external obligations when evidence is well designed.
TPRM-01	Critical Vendor Review	NIST SP 800-161; NIST CSF GV.SC	CIS 15	ISO 27002 5.19	SOC 2 CC9	NIST 800-161 supply chain	One internal control can satisfy multiple external obligations when evidence is well designed.
CHG-01	Production Change Approval	NIST 800-53 CM-3	CIS 4	ISO 27002 8.32	SOC 2 CC8	N/A	One internal control can satisfy multiple external obligations when evidence is well designed.
SEC-01	Security Awareness Training	NIST 800-53 AT-2	CIS 14	ISO 27002 6.3	SOC 2 CC2	N/A	One internal control can satisfy multiple external obligations when evidence is well designed.
DATA-01	Data Retention and Disposal	NIST 800-53 SI-12	CIS 3	ISO 27002 5.33	SOC 2 Confidentiality	N/A	One internal control can satisfy multiple external obligations when evidence is well designed.
CLD-01	Cloud Configuration Monitoring	NIST 800-53 CM-2, AC-3	CIS 4	ISO 27017:2026	SOC 2 CC7	ISO 27017 cloud-specific	One internal control can satisfy multiple external obligations when evidence is well designed.

Control ID	Control	Test Procedure	Evidence Reviewed	Sample Size	Pass Count	Conclusion	Exception	Severity	Remediation
AC-01	MFA Enforcement	Inspect IdP policy and sample 25 users including all privileged users.	MFA policy export; user enrollment report	25	23	Exception	Two contractor accounts lacked MFA evidence.	High	Require MFA before contractor access is restored.
AC-02	Quarterly Access Review	Inspect Q2 access review for Salesforce and GitHub.	Access review export; reviewer signoff	2	1	Exception	One review lacked approval timestamp.	Medium	Require dated approval and retained evidence.
VM-01	Vulnerability Scanning	Inspect monthly scan evidence for last three months.	Scan reports; ticket export	3	3	Pass	Scans completed; aging report can be improved.	Low	Add aging summary to monthly report.
IR-02	Incident Tabletop	Inspect annual tabletop evidence.	IR plan; exercise evidence	1	0	Exception	No current-year tabletop evidence.	Medium	Schedule tabletop and track lessons learned.
TPRM-01	Critical Vendor Review	Inspect critical vendor assessment evidence for DataFlow AI.	Assessment workbook; findings tracker	1	1	Pass	Conditional approval documented with open findings.	Low	Continue tracking vendor remediation.

Finding ID	Control ID	Finding	Severity	Root Cause	Risk	Remediation	Owner
CF-001	AC-01	Two contractor accounts lacked MFA evidence	High	Contractor onboarding not included in MFA evidence review	Unauthorized access risk and audit exception	Require MFA for contractors and update onboarding checklist	VP of IT
CF-002	AC-02	Q2 access review missing approval timestamp	Medium	Evidence retention process incomplete	Review cannot be fully evidenced	Require dated approval workflow	GRC Lead
CF-003	IR-02	No current-year tabletop evidence	Medium	Exercise not scheduled before readiness review	IR readiness not proven	Schedule tabletop and track lessons learned	CISO

Control ID	Evidence Request	Owner	Frequency	Acceptable Evidence	Learning Point
AC-01	MFA policy export; enrollment report; exception log	VP of IT	Continuous	MFA policy export; enrollment report; exception log	Evidence must prove the control objective, not just show that a tool exists.
AC-02	Access review export; reviewer signoff; remediation evidence	GRC Lead	Quarterly	Access review export; reviewer signoff; remediation evidence	Evidence must prove the control objective, not just show that a tool exists.
AC-03	HR termination ticket; SSO deactivation log	People Ops	Per termination	HR termination ticket; SSO deactivation log	Evidence must prove the control objective, not just show that a tool exists.
VM-01	Scan report; ticket export	Security Engineer	Monthly	Scan report; ticket export	Evidence must prove the control objective, not just show that a tool exists.
VM-02	Aging report; exception approvals	Security Engineer	Monthly	Aging report; exception approvals	Evidence must prove the control objective, not just show that a tool exists.
LOG-01	Log source inventory; alert routing matrix	Security Operations	Continuous	Log source inventory; alert routing matrix	Evidence must prove the control objective, not just show that a tool exists.
IR-01	IR plan; approval record	CISO	Annual	IR plan; approval record	Evidence must prove the control objective, not just show that a tool exists.
IR-02	Exercise agenda; participant list; lessons learned	CISO	Annual	Exercise agenda; participant list; lessons learned	Evidence must prove the control objective, not just show that a tool exists.
BC-01	Backup job logs; failure tickets	Infrastructure	Daily	Backup job logs; failure tickets	Evidence must prove the control objective, not just show that a tool exists.
BC-02	Restore test record; RTO/RPO results	Infrastructure	Annual	Restore test record; RTO/RPO results	Evidence must prove the control objective, not just show that a tool exists.
TPRM-01	Vendor assessment; SOC report; findings register	GRC Lead	Annual	Vendor assessment; SOC report; findings register	Evidence must prove the control objective, not just show that a tool exists.
CHG-01	Pull request; approval; emergency review record	Engineering Manager	Per change	Pull request; approval; emergency review record	Evidence must prove the control objective, not just show that a tool exists.
SEC-01	Training completion report	People Ops	Annual	Training completion report	Evidence must prove the control objective, not just show that a tool exists.
DATA-01	Retention matrix; deletion evidence	Legal / Privacy	Annual	Retention matrix; deletion evidence	Evidence must prove the control objective, not just show that a tool exists.
CLD-01	Configuration alerts; exception review	Cloud Engineering	Monthly	Configuration alerts; exception review	Evidence must prove the control objective, not just show that a tool exists.

Reference	URL	Use
NIST CSF 2.0	https://www.nist.gov/cyberframework	Program outcomes and governance alignment
NIST SP 800-53 Rev. 5 Release 5.2.0	https://csrc.nist.gov/News/2025/nist-releases-revision-to-sp-800-53-controls	Control catalog reference
NIST SP 800-53A Rev. 5	https://csrc.nist.gov/pubs/sp/800/53/a/r5/final	Control assessment and test procedure reference
CIS Controls v8.1	https://www.cisecurity.org/controls/v8-1	Practical safeguard mapping
ISO/IEC 27001:2022/Amd 1:2024	https://www.iso.org/standard/88435.html	ISMS requirements
ISO/IEC 27002:2022	https://www.iso.org/standard/75652.html	Security control guidance
ISO/IEC 27017:2026	https://www.iso.org/standard/43757.html	Cloud-service control guidance
AICPA Trust Services Criteria with revised points of focus 2022	https://www.aicpa-cima.com/resources/download/2017-trust-services-criteria-with-revised-points-of-focus-2022	SOC 2 readiness criteria
NIST SP 800-61 Rev. 3	https://csrc.nist.gov/pubs/sp/800/61/r3/final	Incident-response control guidance
NIST SP 800-161 Rev. 1 Update 1	https://csrc.nist.gov/pubs/sp/800/161/r1/upd1/final	Supply-chain controls
Scenario dates and rating definitions	Fictional assessment assumptions; see shared company profile	../00-company-profile/Northbridge-Company-and-GRC-Scope.md